

Report Progetto S3-L5: Creazione di policy Firewall con pfSense

Obiettivo:

Creare una regola firewall che blocchi l'accesso alla DVWA (su metasploitable) dalla macchina Kali Linux e ne impedisca di conseguenza lo scan. Un requisito fondamentale dell'esercizio è che le macchine Kali e Metasploitable siano su reti diverse.

1. Introduzione e Contesto:

Il progetto simula un contesto reale in cui un amministratore di rete deve isolare due macchine su due subnet separate, ma entrambe connesse a pfSense, e controllare selettivamente la comunicazione tra di esse, bloccando l'accesso a un servizio specifico (la web application vulnerabile **DVWA**) senza interrompere la connettività generale tra le due machine, tramite regole specifiche configurate su Sense.

2. Strumenti Utilizzati e Topologia di Rete:

2.1 — Macchine Virtuali:

Il laboratorio è composto da tre macchine virtuali, ciascuna con un ruolo distinto:

VM	Sistema Operativo	IP / Subnet	Ruolo
pfSense	FreeBSD 2.8.1	WAN: 10.0.2.15/24 LAN_KALI: 192.168.3.1/24 LAN_META: 192.168.4.1/24	Firewall / Router
Kali Linux	Kali 2026.1	192.168.3.100/24	Attaccante / Tester
Metasploitable 2.0	Ubuntu (vuln.)	192.168.4.100/24	Target vulnerabile

2.2 — Schema di Rete

La topologia prevede pfSense come nodo centrale con tre interfacce di rete: una WAN verso l'esterno e due interfacce LAN interne, ciascuna collegata a una subnet dedicata. Kali Linux e Metasploitable 2.0 non sono collegate direttamente tra loro: tutto il traffico tra reti traffica attraverso pfSense.

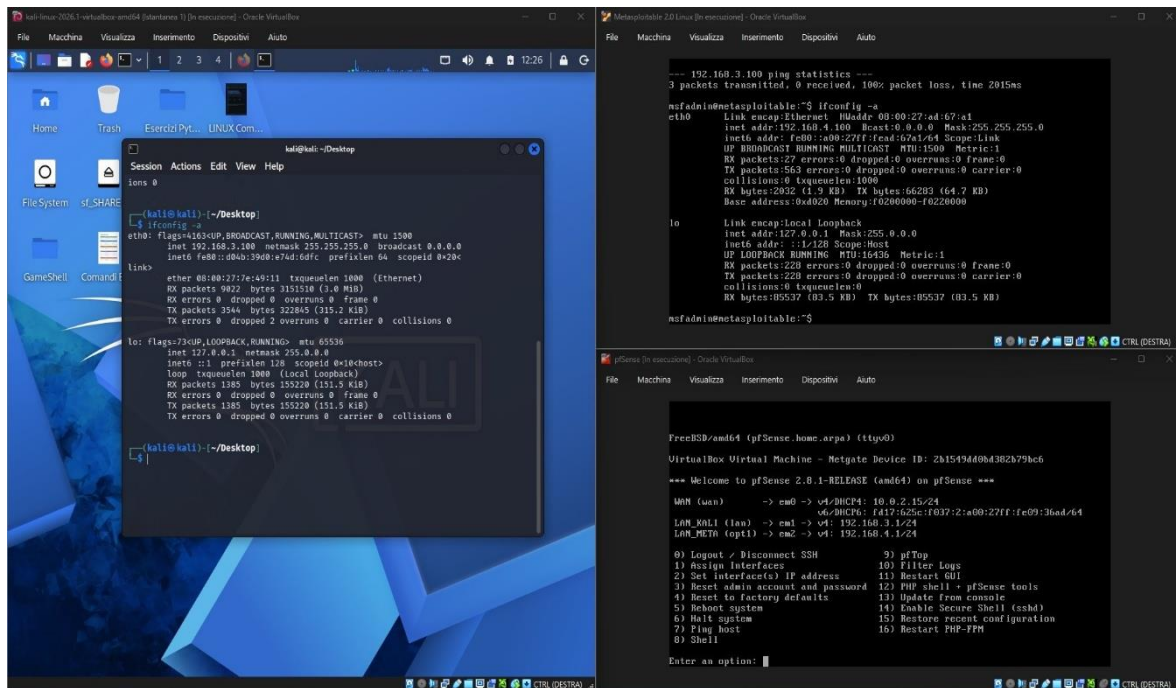


Figura 1 — Overview delle tre VM con IP assegnati: Kali (192.168.3.100), Metasploitable (192.168.4.100), pfSense con LAN_KALI (192.168.3.1) e LAN_META (192.168.4.1)

3. Procedura Svolta:

3.1 — Configurazione dell'Ambiente Virtuale:

Il primo passo è stato quello di configurare le schede di rete delle tre macchine virtuali all'interno di VirtualBox. Per garantire l'isolamento delle reti, è stato utilizzato il tipo di adattatore **Rete Interna**.

1 pfSense — 3 adattatori di rete:

Adattatore 1: NAT (WAN, accesso Internet).
Adattatore 2: Rete Interna 'LAN_KALI' (interfaccia em1).
Adattatore 3: Rete Interna 'LAN_META' (interfaccia em2).

2 Kali Linux — 1 adattatore:

Adattatore 1: Rete Interna 'LAN_KALI' — IP: 192.168.3.100/24

3 Metasploitable 2.0 — 1 adattatore:

Adattatore 1: Rete Interna 'LAN_META' — IP: 192.168.4.100/24.

4 Configurazione interfacce pfSense:

WAN → em0 (DHCP),
LAN_KALI → em1 (192.168.3.1/24),
(OPT1) LAN_META → em2 (192.168.4.1/24).

3.2 — Configurazione delle Regole di Base per la Comunicazione:

Una volta configurate le interfacce, pfSense blocca di default tutto il traffico sulle interfacce OPT (rinominata "LAN_META"). È stato quindi necessario creare delle regole *Allow* per abilitare la comunicazione bidirezionale tra le due subnet.

Le regole sono state inserite nella WebGUI di pfSense da Kali, alla sezione **Firewall → Rules**.

È importante ricordare che pfSense applica le regole **in ingresso sull'interfaccia di provenienza** del traffico, dall'alto verso il basso: la prima regola che fa match viene applicata.

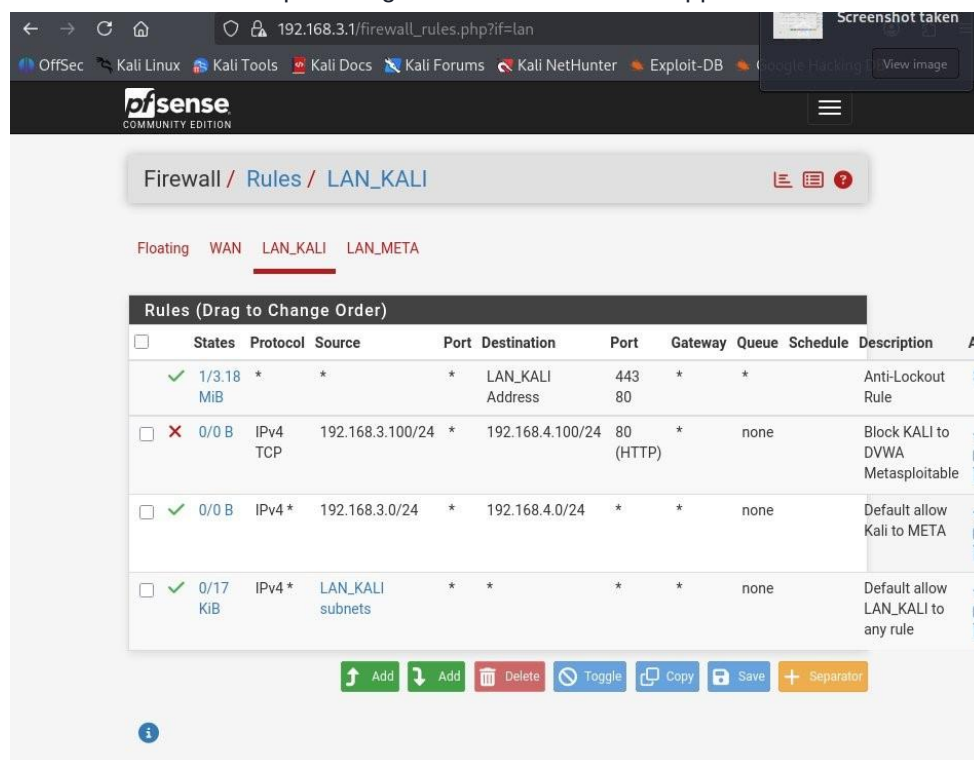


Figura 2 — Regole sull'interfaccia LAN KALI: si notano la regola di blocco e le regole di allow generale verso LAN META.

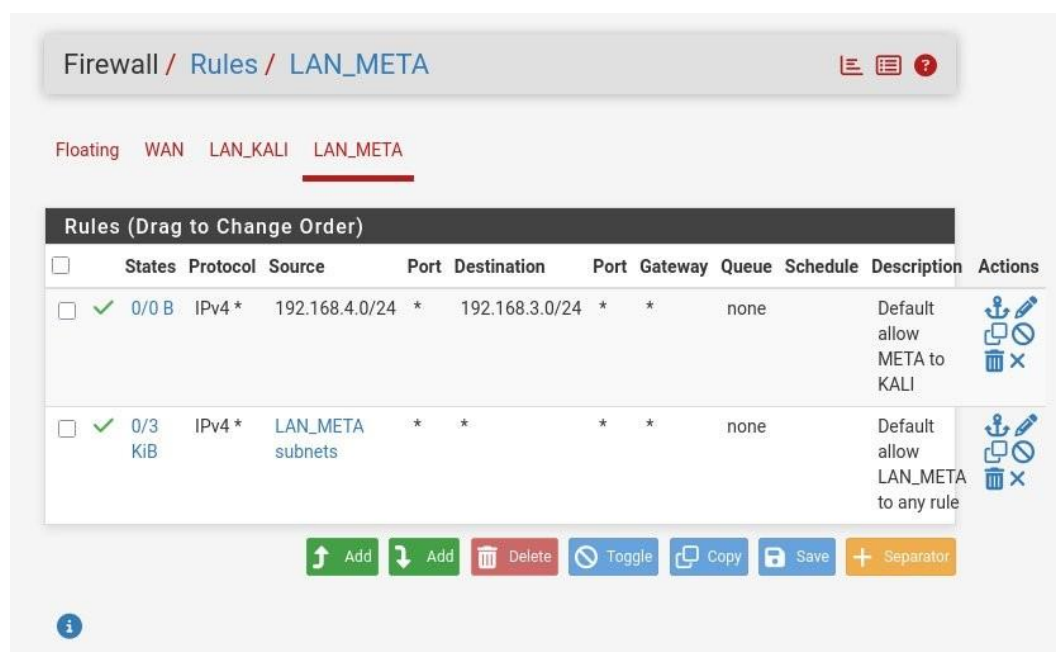


Figura 3 — Regole sull'interfaccia LAN_META: allow bidirezionale verso LAN_KALI e regola di default che permette tutto il traffico in uscita dalla subnet Metasploitable.

3.3 — Verifica della Comunicazione tra le due VM:

Prima di procedere con la regola di blocco, ho quindi verificato la corretta comunicazione bidirezionale tra Kali e Metasploitable tramite il comando **ping**. Il test è stato eseguito in entrambe le direzioni.

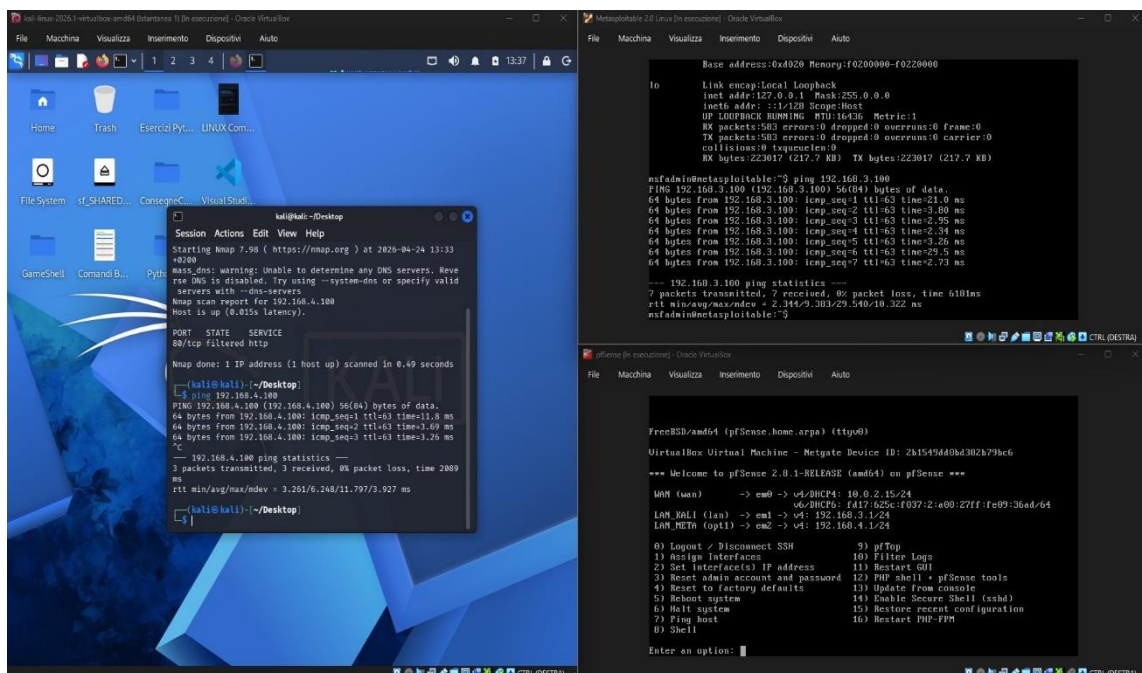


Figura 4 — Test ping bidirezionale: Metasploitable (destra, in alto) pinga Kali con successo (0% packet loss), e Kali (sinistra) raggiunge Metasploitable. La comunicazione attraverso pfSense funziona correttamente.

3.4 — Implementazione della Regola di Blocco per DVWA (porta 80):

Con la comunicazione generale funzionante, ho proceduto configurando la regola firewall che costituisce il cuore dell'esercizio: **bloccare selettivamente l'accesso alla porta 80 (HTTP) di Metasploitable**, dove risiede l'applicazione DVWA (Damn Vulnerable Web Application), mantenendo però attiva la comunicazione generica tra le due machine.

La regola è stata inserita sull'interfaccia **LAN_KALI**:

Campo	Valore impostato
Action	Block
Interface	LAN_KALI
Protocol	TCP
Source	192.168.3.100/24 (Kali Linux)
Destination	192.168.4.100/24 (Metasploitable)
Dest. Port	80 (HTTP)
Description	Block KALI to DVWA Metasploitable

4. Verifica dei Risultati:

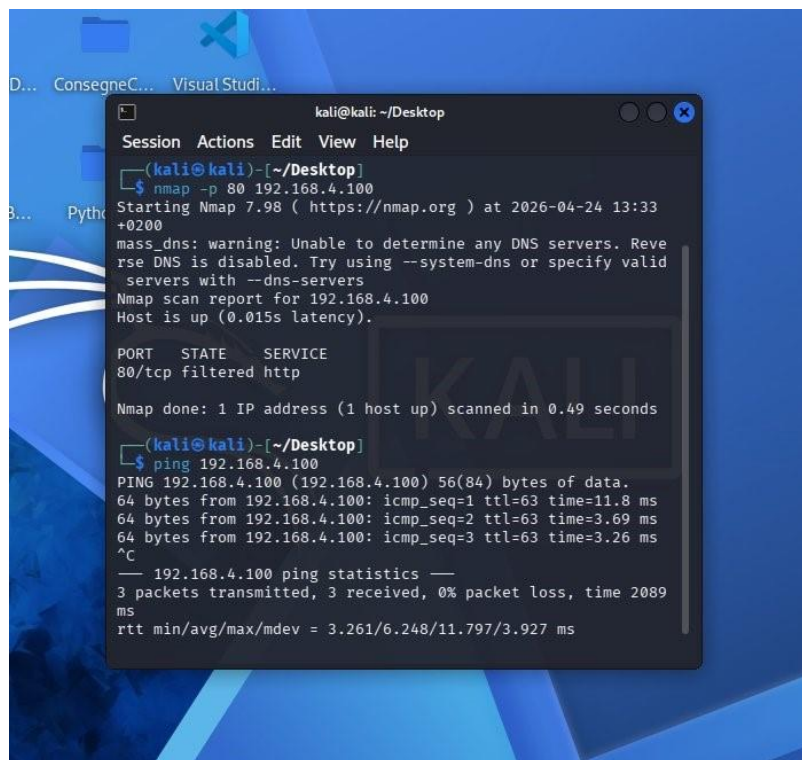
Al termine della configurazione, ho eseguito i test di verifica per confermare che la regola firewall funzionasse come previsto: blocco selettivo della porta 80 con mantenimento della connettività generale.

4.1 — Test con Nmap

Il tool **Nmap** è stato utilizzato per verificare lo stato della porta 80 di Metasploitable dalla macchina Kali. Il risultato atteso è lo stato *filtered*, che indica che i pacchetti vengono droppati dal firewall.

4.2 — Test di Connettività Generale (Ping)

È stato contestualmente verificato che la comunicazione (ping) tra Kali e Metasploitable fosse ancora attiva, confermando che il blocco è selettivo alla sola porta 80 e non compromette la comunicazione generale.



```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)~[~/Desktop]
$ nmap -p 80 192.168.4.100
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 13:33 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.4.100
Host is up (0.015s latency).

PORT      STATE SERVICE
80/tcp    filtered http

Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds

(kali@kali)~[~/Desktop]
$ ping 192.168.4.100
PING 192.168.4.100 (192.168.4.100) 56(84) bytes of data:
64 bytes from 192.168.4.100: icmp_seq=1 ttl=63 time=11.8 ms
64 bytes from 192.168.4.100: icmp_seq=2 ttl=63 time=3.69 ms
64 bytes from 192.168.4.100: icmp_seq=3 ttl=63 time=3.26 ms
^C
— 192.168.4.100 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2089 ms
rtt min/avg/max/mdev = 3.261/6.248/11.797/3.927 ms
```

Figura 5 — Verifica finale: nmap riporta la porta 80 come 'filtered' (blocco attivo), mentre il ping verso 192.168.4.100 risponde correttamente (0% packet loss). La policy firewall funziona in modo selettivo e corretto.

Risultato

La porta 80 (DVWA) risulta FILTERED → pfSense blocca il traffico HTTP da Kali. Il ping funziona regolarmente → la connettività generale è preservata. La policy firewall è stata implementata con successo.

5. Difficoltà Incontrate e Considerazioni:

5.1 — Difficoltà Incontrate

Durante l'esecuzione del progetto ho incontrato alcune difficoltà:

1. **Configurazione dell'ambiente virtuale:** assegnare correttamente le schede di rete in VirtualBox utilizzando il tipo 'Rete Interna' con nomi coerenti tra le tre VM ha richiesto attenzione per evitare connessioni errate tra le macchine.
2. **Comunicazione tra le VM:** inizialmente le due VM non riuscivano a comunicare. Il problema era l'assenza di un gateway configurato sulle macchine e la mancanza delle regole Allow su pfSense per le interfacce OPT, che di default blocca tutto.
3. **Inserimento delle regole su pfSense:** capire la logica di pfSense nella scrittura e nella assegnazione corretta delle regole alle rispettive interfacce.
4. **Capire come andare a bloccare la comunicazione solo con DVWA:** essendo che pfSense simula un firewall che filtra solo secondo indirizzi IP e porte di rete, e non per singoli servizi o URL, è stato inizialmente complicato capire quale regola applicare secondo la richiesta del progetto.
5. **Blocco selettivo porta 80:** trovare la configurazione corretta per bloccare solo il traffico TCP verso la porta 80 di Metasploitable, senza interrompere l'intera comunicazione tra le subnet, è stato il passaggio più delicato dell'esercizio.

5.2 — Considerazioni Tecniche

Questo esercizio ha permesso di comprendere concretamente come funziona un firewall come pfSense in un contesto di rete segmentata. La segmentazione in subnet distinte è una pratica fondamentale nella sicurezza delle reti aziendali, in quanto limita il movimento laterale di un potenziale attaccante.

La possibilità di bloccare selettivamente un singolo servizio (porta 80 su un host specifico) mantenendo attiva la connettività generale dimostra la granularità con cui un firewall ben configurato può controllare il traffico di rete, applicando il principio del **minimo privilegio** anche a livello di comunicazioni di rete.

6. Conclusioni

Il progetto è stato completato con successo. Ho raggiunto tutti gli obiettivi previsti dall'esercizio: configurazione di un ambiente virtuale multi-subnet, abilitazione della comunicazione inter-rete tramite pfSense, e implementazione di una policy firewall che blocca selettivamente l'accesso a DVWA (porta 80) su Metasploitable dalla macchina Kali Linux.

I test finali hanno confermato il corretto funzionamento della configurazione: la porta 80 risulta in stato *filtered* nella scansione Nmap, mentre il ping tra le due macchine continua a funzionare regolarmente, dimostrando la selettività della regola implementata.

L'esercizio ha fornito una comprensione pratica di concetti fondamentali come la segmentazione di rete, il funzionamento dei firewall stateful, e l'importanza dell'ordine delle regole in un sistema come pfSense.

Obiettivo	Stato
Configurazione ambiente multi-subnet	✓ Completato
Comunicazione Kali ↔ Metasploitable attiva	✓ Verificato
Blocco porta 80 (DVWA) da Kali	✓ Attivo — porta filtered
Ping ancora funzionante	✓ Confermato